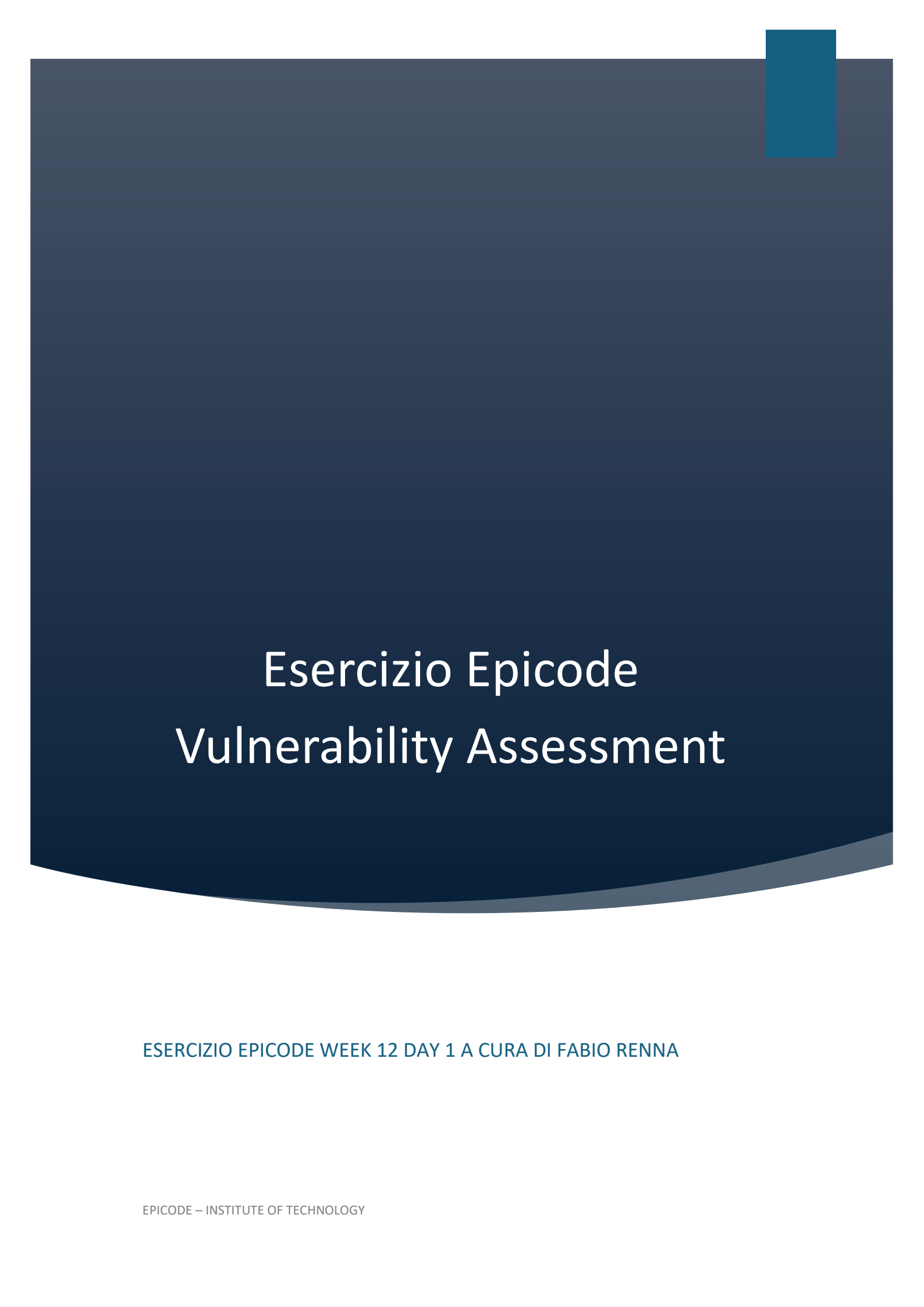




Esercizio Epcode Vulnerability Assessment

ESERCIZIO EPICODE WEEK 12 DAY 1 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	4 -10
Conclusione.....	10

Executive Summary

È stata eseguita una scansione di Vulnerability Assessment sulla macchina **Metasploitable 2 (IP 192.168.50.101)** tramite **Nessus Essentials**, limitando l'analisi alle **porte comuni** come richiesto dalla traccia.

L'analisi ha identificato **63 vulnerabilità totali**, tra cui:

- **9 Critiche**
- **5 Alte**
- **22 Medie**
- **8 Basse**
- **127 Informative**

Le vulnerabilità critiche includono debolezze gravi come **backdoor attive, protocolli SSL obsoleti, password VNC deboli e una vulnerabilità Ghostcat su Apache Tomcat**, che consentono potenzialmente l'esecuzione di codice remoto o accesso non autorizzato al sistema.

I risultati confermano che Metasploitable è estremamente vulnerabile e deve essere considerata una macchina deliberatamente insicura. Tuttavia, lo scopo dell'esercizio è proprio fornire allo studente un ambiente realistico per comprendere e classificare vulnerabilità critiche frequentemente riscontrate durante penetration test reali.

Introduzione

Lo scopo di questo esercizio è eseguire una scansione di Vulnerability Assessment sulla macchina Metasploitable utilizzando Nessus, concentrandosi sulle porte più comunemente esposte in contesti reali (HTTP, HTTPS, SSH, FTP, VNC, SMB, RPC, SQL, ecc.).

L'attività consente allo studente di:

- acquisire familiarità con la configurazione di Nessus,

- interpretare i risultati della scansione,
- comprendere la severità delle vulnerabilità rilevate,
- consultare riferimenti esterni per lo studio e la remediation.

L'analisi si focalizza sulle vulnerabilità rilevate e sulla loro potenziale criticità dal punto di vista di un penetration tester.

Obiettivo

❓ **Configurare e lanciare correttamente una scansione Nessus**, limitata alle porte comuni.

❓ **Analizzare nel dettaglio ogni vulnerabilità rilevata**, leggendo:

- descrizione
- impatto
- evidenze tecniche (output Nessus)
- soluzioni proposte
- riferimenti esterni

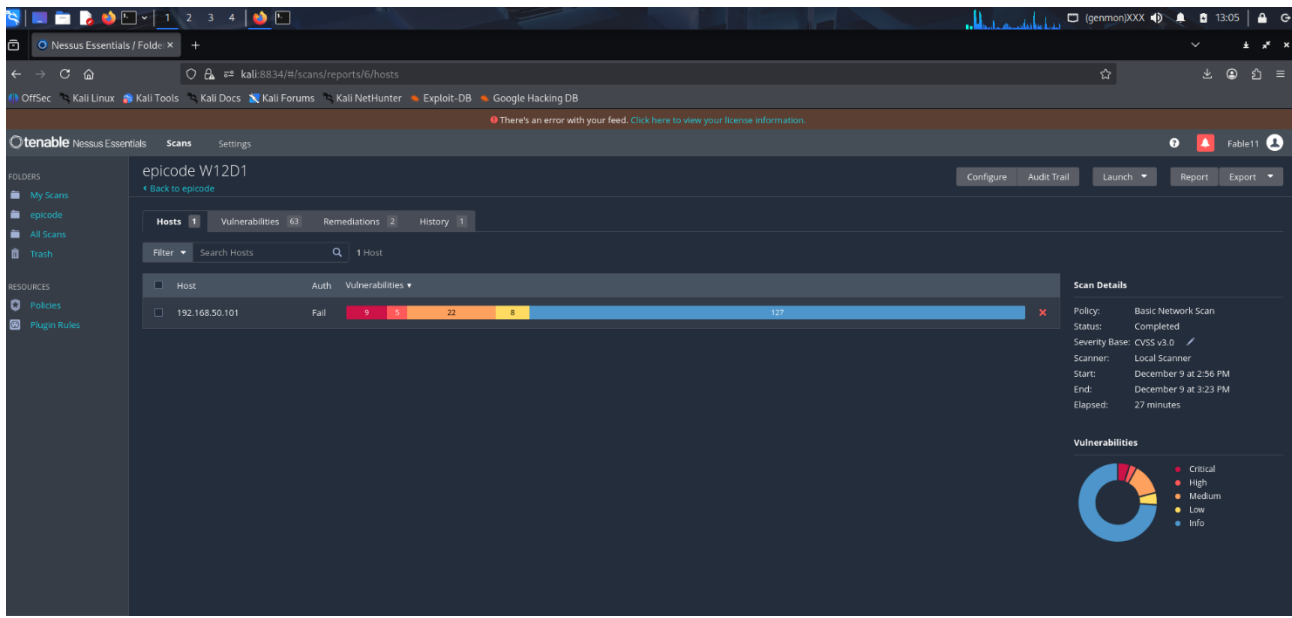
❓ **Comprendere alcune vulnerabilità note ricorrenti**, tra cui:

- Backdoor attive ("Bind Shell Backdoor Detection")
- Password deboli o predefinite
- Protocolli obsoleti (SSL 2/3)
- Tomcat Ghostcat (AJP Injection)
- Sistema operativo End-of-Life

❓ **Produrre un report tecnico quasi completo**, con:

- porte vulnerabili
- descrizione vulnerabilità
- impatti
- remediation
- riferimenti

Proof of Concept



Questo screenshot mostra la schermata principale del report generato da Nessus al termine della scansione sulla macchina Metasploitable (IP 192.168.50.101). Il risultato evidenzia come il target presenti un totale di **63 vulnerabilità**, suddivise in diversi livelli di criticità: **9 critiche, 5 alte, 22 medie, 8 basse e 127 informative**. La sezione “Auth: Fail” indica che Nessus non è riuscito ad autenticarsi sulla macchina target, procedendo quindi con una scansione non autenticata. Il grafico a torta e la barra colorata forniscono una rappresentazione immediata dello stato di sicurezza complessivo del sistema, evidenziando una superficie d'attacco estremamente ampia e numerose debolezze sfruttabili.

Sev	CVSS	VPR	EPSS	Name	Family	Count	
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
HIGH	7.5	5.9	0.7993	Samba Badlock Vulnerability	General	1	
HIGH	7.5			NFS Shares World Readable	RPC	1	

Lo screenshot mostra la sezione del report Nessus dedicata alle vulnerabilità classificate come **Critiche** e **High** sul sistema Metasploitable. In questa vista sono elencate alcune delle debolezze più pericolose, incluse un sistema operativo obsoleto e fuori supporto (Ubuntu 8.04.x), una password VNC estremamente debole, un

backdoor di tipo bind shell e vulnerabilità sfruttabili su Tomcat (Ghostcat) e protocolli SSL obsoleti. Ogni riga include punteggi CVSS, indicatori di rischio predittivo (VPR, EPSS), categoria della minaccia e conteggio delle occorrenze, permettendo una rapida valutazione del livello di esposizione. L'insieme di queste criticità evidenzia come il sistema sia altamente compromettibile e richieda interventi immediati di mitigazione.

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description

According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution

Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also

<http://www.nessus.org/u?3bdb2d2e>

Output

```
OS : Ubuntu Linux 8.04
Security End of Life : May 9, 2013
Time since Security End of Life (Est.) : >= 12 years
```

To see debug logs, please visit individual host

Port ▲	Hosts
80 / tcp / www	192.168.50.101 

o screenshot mostra una vulnerabilità classificata come **Critica**, relativa all'utilizzo di una versione del sistema operativo **Ubuntu Linux 8.04**, ormai *End of Life* dal **9 maggio 2013**. Ciò significa che il sistema non riceve più aggiornamenti di sicurezza da oltre 12 anni, rendendolo esposto a numerose minacce non patchate. Nessus evidenzia che la mancanza di supporto espone l'host a vulnerabilità note, potenzialmente sfruttabili da un attaccante per ottenere esecuzione di codice, escalation di privilegi o compromissione completa del sistema. L'unica soluzione proposta è l'aggiornamento immediato a una versione supportata di Ubuntu, essendo impossibile mitigare efficacemente rischi così estesi su una piattaforma obsoleta. Dal pannello inferiore si nota che la vulnerabilità è stata rilevata tramite il servizio HTTP esposto sulla porta **80/tcp**, confermando che l'host analizzato risulta attivo e visibile in rete.

[5]

CRITICAL

VNC Server 'password' Password

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

Nessus logged in using a password of "password".

To see debug logs, please visit individual host

Port ▲	Hosts
5900 / tcp / vnc	192.168.50.101 

Questo screenshot evidenzia una vulnerabilità classificata come **Critica**, relativa al servizio **VNC** in ascolto sulla porta **5900/tcp**. Nessus ha verificato che il server utilizza come credenziale di accesso la password predefinita **"password"**, estremamente debole e facilmente indovinabile. L'autenticazione è risultata talmente insufficiente che lo scanner è riuscito ad accedere direttamente al sistema remoto senza alcuna resistenza, dimostrando la possibilità reale di compromissione.

Una configurazione di questo tipo permette a un attaccante remoto non autenticato di ottenere il pieno controllo della macchina, con la possibilità di eseguire comandi, accedere ai file e manipolare servizi critici. La soluzione raccomandata da Nessus consiste nel sostituire immediatamente la password con una credenziale complessa e, se possibile, nel configurare ulteriori misure di sicurezza come restrizioni IP, cifratura del canale e autenticazione avanzata.

CRITICAL

Apache Tomcat AJP Connector Request Injection (Ghostcat)

Description

A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

Solution

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

See Also

<http://www.nessus.org/u?8ebe6246>
<http://www.nessus.org/u?4e287adb>
<http://www.nessus.org/u?cbc3d54e>
<https://access.redhat.com/security/cve/CVE-2020-1745>
<https://access.redhat.com/solutions/4851251>
<http://www.nessus.org/u?dd218234>
<http://www.nessus.org/u?dd772531>
<http://www.nessus.org/u?2a01d6bf>
<http://www.nessus.org/u?3b5af27e>
<http://www.nessus.org/u?9dab109f>
<http://www.nessus.org/u?5eafcf70>

Output

```

Nessus was able to exploit the issue using the following request :

0x0000:  02 02 00 08 48 54 54 50 2F 31 2E 31 00 00 0F 2F    ...HTTP/1.1.../
0x0010:  61 73 64 66 2F 78 78 78 78 2E 6A 73 70 00 00      asdf/xxxxx.jsp..
0x0020:  09 6C 6F 63 61 6C 68 6F 73 74 00 FF FF 00 09 6C  .localhost.....
0x0030:  6F 63 61 6C 68 6F 73 74 00 00 50 00 00 09 A0 06  ocalhost..P.....
0x0040:  00 0A 6B 65 65 70 2D 61 6C 69 76 65 00 00 0F 41  ..keep-alive...A

```

Questo screenshot mostra una vulnerabilità **Critica** relativa al connettore **AJP (Apache JServ Protocol)** utilizzato dal server Apache Tomcat. La falla, nota come **Ghostcat (CVE-2020-1938)**, consente a un attaccante remoto non autenticato di effettuare **file read/inclusion** tramite richieste appositamente costruite verso il servizio AJP. In molti scenari, questa vulnerabilità permette anche di caricare file JSP malevoli e ottenere **esecuzione di codice remoto (RCE)** sul server, rendendola estremamente pericolosa.

Nel riquadro "Output" si vede che Nessus è stato in grado di **sfruttare attivamente la vulnerabilità**, inviando una richiesta AJP manipolata e ottenendo una risposta contenente dati non autorizzati. Questo conferma che il servizio è vulnerabile e non adeguatamente protetto da controlli di autenticazione o restrizioni.

La soluzione consigliata consiste nell'aggiornare il server Tomcat a una versione corretta ($\geq 7.0.100$, 8.5.51, 9.0.31) oppure nel configurare l'AJP Connector per richiedere autenticazione o limitarne l'accesso esclusivamente a host fidati.

Questa vulnerabilità rappresenta uno dei punti di ingresso più gravi su Metasploitable, poiché può portare al totale compromesso del sistema.

CRITICAL

SSL Version 2 and 3 Protocol Detection

Description

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution

Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

See Also

<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>
<http://www.nessus.org/u?b06c7e95>

Questo screenshot evidenzia una vulnerabilità critica legata all'uso di protocolli SSL obsoleti (SSL 2.0 e SSL 3.0) rilevati sul sistema target. Questi protocolli presentano **debolezze crittografiche note**, tra cui l'uso di cifrari insicuri (CBC con problemi di padding), la possibilità di attacchi di renegotiation e vulnerabilità note come **POODLE**, che permettono a un attaccante di effettuare downgrade dell'handshake o decryptare parte del traffico.

La presenza di SSL 2.0/3.0 implica che il servizio accetta connessioni con protocolli ormai deprecati e considerati insicuri da anni. NIST e gli standard PCI-DSS vietano formalmente l'uso di SSL 3.0 dal 2016, proprio a causa dell'elevato rischio per la confidenzialità delle comunicazioni.

Nella sezione "Description", Nessus dettaglia gli impatti potenziali: un attaccante potrebbe avviare attacchi man-in-the-middle, alterare le sessioni o decifrare parte del traffico SSL intercettato. Questo rende la vulnerabilità estremamente pericolosa, soprattutto se il servizio è esposto pubblicamente.

La soluzione suggerita è chiara: **disabilitare completamente SSL 2.0 e SSL 3.0** e consentire solo protocolli moderni come **TLS 1.2 o superiori**, utilizzando cipher suite robuste e aggiornate. L'adozione di versioni obsolete può portare al compromesso dell'integrità e riservatezza dei dati scambiati.

Questa vulnerabilità è comune nei sistemi legacy come Metasploitable, ed è spesso uno dei primi indicatori di una configurazione non sicura dei servizi HTTPS o AJP.

CRITICAL

Bind Shell Backdoor Detection

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

Nessus was able to execute the command "id" using the following request :

This produced the following truncated output (limited to 10 lines) :
----- snip -----
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
----- snip -----

To see debug logs, please visit individual host

Port ▲	Hosts
1524 / tcp / wild_shell	192.168.50.101

Lo screenshot mostra una delle vulnerabilità più gravi rilevate da Nessus: la presenza di una **bind shell backdoor** attiva sulla porta **1524/tcp** del sistema Metasploitable. Una bind shell è un meccanismo che espone una shell di sistema in ascolto su una porta TCP, consentendo a chiunque si connetta di ottenere accesso diretto al sistema **senza alcuna forma di autenticazione**.

Nessus conferma l'esistenza della backdoor eseguendo con successo il comando `id`, come mostrato nell'output. Il risultato (`uid=0(root)`) indica chiaramente che l'account ottenuto è **root**, ossia il livello massimo di privilegi. Questo significa che un attaccante remoto può prendere il controllo completo del sistema semplicemente stabilendo una connessione alla porta vulnerabile.

Questa vulnerabilità è tipica di ambienti volutamente insicuri come Metasploitable e rappresenta un esempio classico di compromissione totale del sistema tramite servizi non protetti. In un contesto reale, la presenza di una backdoor simile costituirebbe un'emergenza di sicurezza: richiederebbe la verifica dell'intero sistema per capire se l'accesso non autorizzato è stato sfruttato e, nella maggior parte dei casi, una **reinstallazione completa** per garantire l'integrità della macchina.

Lo screenshot dimostra chiaramente:

- la porta esposta,
- l'esecuzione remota di comandi senza autenticazione,
- la conferma dell'elevazione ai privilegi root.

Si tratta quindi di una vulnerabilità critica che consente esecuzione di comandi remoti (RCE) e compromissione totale del sistema.

[9]

CRITICAL

Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)

Description

The remote x509 certificate on the remote SSL server has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

See Also

<http://www.nessus.org/u?107f9bdc>
<http://www.nessus.org/u?f14f4224>

Output

No output recorded.

To see debug logs, please visit individual host

Port ▲	Hosts
5432 / tcp / postgresql	192.168.50.101
25 / tcp / smtp	192.168.50.101

Questo screenshot evidenzia una vulnerabilità critica riconducibile al famoso bug del **Random Number Generator di OpenSSL** introdotto nelle versioni Debian/Ubuntu tra il 2006 e il 2008. A causa di una modifica errata al codice di OpenSSL da parte dei manutentori Debian, la funzione di generazione dei numeri casuali veniva inizializzata con una quantità estremamente ridotta di entropia. Questo comportava che tutte le chiavi crittografiche generate sul sistema fossero **prevedibili**.

Nessus rileva che il certificato SSL del servizio esposto è stato generato utilizzando una versione vulnerabile della libreria OpenSSL, rendendo le chiavi di crittografia facilmente ricostruibili. Un attaccante può quindi ottenere la chiave privata associata al certificato, decifrare il traffico intercettato oppure impersonare completamente il server nei confronti dei client (man-in-the-middle).

Lo screenshot mostra inoltre che la vulnerabilità è associata ai servizi attivi sulle porte **5432/tcp (PostgreSQL)** e **25/tcp (SMTP)**. Anche se l'output non fornisce ulteriori dettagli, la sola presenza di chiavi deboli su servizi di rete rappresenta un rischio gravissimo: qualsiasi comunicazione crittografata può essere compromessa.

La soluzione raccomandata da Nessus consiste nel **rigenerare tutto il materiale crittografico** sul sistema, includendo:

- chiavi SSH,
- certificati SSL,
- chiavi utilizzate da OpenVPN o altri servizi.

La vulnerabilità è ampiamente documentata e rappresenta un punto di riferimento storico nella sicurezza informatica, poiché dimostra come un singolo errore nel sistema di generazione casuale possa invalidare completamente la sicurezza crittografica di un'intera infrastruttura.

Conclusione

La scansione effettuata con Nessus sulla macchina Metasploitable ha evidenziato un numero significativo di vulnerabilità, molte delle quali classificate come **critiche o alte**. Le debolezze identificate includono protocolli insicuri, password deboli, servizi vulnerabili a Remote Code Execution e un sistema operativo non più supportato.

Questi risultati mostrano come una cattiva gestione degli aggiornamenti, la mancanza di hardening e l'uso di protocolli legacy possano esporre un sistema a compromissioni immediate.

L'esercizio ha permesso di:

- comprendere il funzionamento pratico di Nessus,
- imparare a leggere un report professionale,
- riconoscere vulnerabilità comuni nel campo del penetration testing,
- correlare i risultati con i rischi reali e le best practice di remediation.

Il lavoro svolto costituisce una base fondamentale per i prossimi moduli del percorso, dove le vulnerabilità analizzate verranno sfruttate tramite exploit, tecniche di privilege escalation e attività di red teaming.

Venezia, 09/12/2025

Fabio Renna